

AI GOVERNANCE FRAMEWORK

Develom **AI Governance** Methods

How We Ensure and Demonstrate Compliance in Every Solution — from architecture design through production monitoring.

*"Governance is not a layer added at the end. It is an **architectural property** built into the solution from the first conversation."*

THE DEVELOM GOVERNANCE PHILOSOPHY

Every Develom engagement follows a structured governance lifecycle designed for regulated industries where compliance is not optional and documentation must be auditable. The six phases below cover the complete journey from pre-build risk assessment through ongoing operations.



Risk Assessment & Compliance Mapping

Before any architecture is designed, we establish the compliance envelope the solution must operate within.

1.1

AI Risk Classification

Every solution is classified on two axes before build begins:

- **Data sensitivity:** Public / Internal / Confidential / Regulated (PHI, PII, financial records)
- **Decision autonomy:** Advisory → Assisted → Autonomous

High autonomy + high sensitivity = mandatory governance controls documented before build begins.

1.2

Regulatory Requirement Mapping

REGULATION	KEY REQUIREMENTS WE MAP
HIPAA	PHI handling, access logs, minimum necessary principle, BAA requirements
SOC 2 Type II	Availability, confidentiality, processing integrity, security, privacy
GDPR / CCPA	Data subject rights, consent management, retention policies, cross-border transfer
FINRA / SEC	Record retention, audit trails, supervisory controls
NIST AI RMF	Risk identification, measurement, management, and governance framework

1.3

Data Classification & Flow Mapping

Before build: every data input, transformation, storage, and output is documented. We identify which data elements are regulated, who can access them, and how long they are retained.

P2

PHASE 2 — DESIGN

Governance Architecture

2.1

Privacy by Design

- **Data minimization:** only what is strictly necessary is collected and processed
- **Purpose limitation:** data collected for one purpose is not reused for another without explicit design decision
- **Storage limitation:** retention policies defined upfront and enforced by the system

2.2

Access Control Architecture

- Role-Based Access Control (RBAC) for all system components
- Principle of least privilege: every agent, service, and user has only required permissions
- Service account isolation: AI agents run under dedicated, scoped accounts — never shared credentials
- Secret management: credentials stored in Google Secret Manager or vault — never hardcoded

2.3

Human-in-the-Loop Checkpoints

For autonomous agents, explicit checkpoints require human review before consequential actions:

- Thresholds for when the agent escalates vs. acts
- Override and correction mechanisms
- Audit log of every autonomous decision and its inputs

2.4

Audit Trail Architecture

Immutable, queryable logs of every agent action, data access event, model input/output, and user interaction — write-once, tamper-evident, retained per applicable regulation.

3.1

Prompt Security & Injection Prevention

- System prompts are versioned, reviewed, and locked — not editable at runtime
- Input sanitization to prevent prompt injection attacks
- Output parsing with guardrails before any action is taken on model output

3.2

Hallucination & Output Controls

- RAG systems: responses grounded in verified source documents with citation
- Confidence thresholds: low-confidence outputs route to human review, not action
- Output filtering: PII and sensitive data detected and redacted before display or transmission
- Structured output validation: schema validation enforced where agents return structured data

3.3

PII Detection & Redaction

- Automated PII detection on all inputs entering the model
- Redaction or tokenization before data reaches the LLM layer where regulated
- De-identification for analytics use cases

3.4

Encryption

- **At rest:** AES-256, Customer-Managed Encryption Keys (CMEK) on GCP where required
- **In transit:** TLS 1.2+ enforced on all API calls and data transfers

3.5

Model & Vendor Risk Documentation

- Written documentation of which AI models are used and their data handling policies
- For regulated industries: confirmation that model vendor has no training data retention on API calls
- Vendor risk assessment completed and documented per engagement

P4

PHASE 4 — VALIDATION

Testing & Compliance Verification

4.1

Adversarial / Red Team Testing

Before any production deployment: prompt injection, jailbreak, and role-confusion attacks are attempted on the deployed agent. Edge cases where the agent might take a high-risk autonomous action incorrectly are tested. All findings and mitigations are documented.

4.2

Bias & Fairness Evaluation

For solutions that make recommendations affecting people: outputs are tested across demographic dimensions for systematic bias. Methodology and findings are documented, and an ongoing monitoring approach is defined.

4.3

Compliance Checklist Sign-Off

A written checklist — specific to the applicable regulations, tied to the risk assessment from Phase 1 — is completed and signed off before go-live.

4.4

Model Card & System Documentation

Every delivered solution includes:

- **Model card:** what model is used, training basis, known limitations, intended use
- **System architecture diagram:** annotated with data flows, trust boundaries, access control boundaries
- **Governance summary:** one-page summary of controls applied, regulations addressed, and monitoring in place

5.1

GCP Security Controls — Standard Stack

- **VPC isolation:** AI workloads run in dedicated VPCs with private endpoints
- **IAM least privilege:** every service account scoped to minimum required permissions
- **Cloud Armor / WAF:** applied to public-facing AI endpoints
- **Binary Authorization:** only verified, approved container images run in production
- **Security Command Center:** continuous threat detection and misconfiguration alerts

5.2

Deployment Review Gate

No solution moves to production without confirming:

- All governance controls are implemented and verified
- Monitoring is active and alerts are configured
- Rollback procedure is documented and tested
- Incident response path is defined



PHASE 6 — OPERATIONS

Ongoing Governance

6.1

Continuous Monitoring

- Agent behavior monitored for drift from expected patterns
- Anomalous outputs flagged for human review
- Access logs reviewed for unexpected data access patterns

6.2

Model Performance & Drift Monitoring

- Output quality tracked over time — models degrade as the world changes
- Scheduled re-evaluation of solution accuracy against ground truth
- Retraining or model upgrade triggers defined upfront

6.3

Regular Compliance Reviews

- Quarterly review of regulatory changes that may affect the solution
- Annual full compliance reassessment
- Event-triggered review on: regulatory change, security incident, or significant model update

6.4

Data Retention & Deletion Enforcement

- Automated enforcement of retention schedules — not manual process
- Data subject deletion requests handled with documented process and confirmation
- Deletion is logged and auditable

How We Demonstrate This to Clients

Governance is only valuable if it can be shown. For each engagement, Develom produces:

DELIVERABLE	WHAT IT PROVES
Risk Assessment Report	We understood your compliance environment before we built
Governance Architecture Diagram	Controls are embedded in the design, not added after

DELIVERABLE	WHAT IT PROVES
Compliance Checklist Sign-Off	Specific regulatory requirements were verified before go-live
Model Card & System Docs	You know exactly what's running in your environment
Audit Log Access	You can prove what the AI did and when — to regulators, auditors, or counsel
Red Team Summary	The system was tested against adversarial conditions before customer exposure



"Before we write a line of code, we map your compliance requirements. We build governance into the architecture. Before go-live, we red team the system and sign off a compliance checklist. After launch, we monitor for drift. At any point, you can show a regulator exactly what the AI did, why, and what controls were in place. That's not a feature. That's the foundation."

— HECTOR DEJESUS, FOUNDER & CEO, DEVELOM